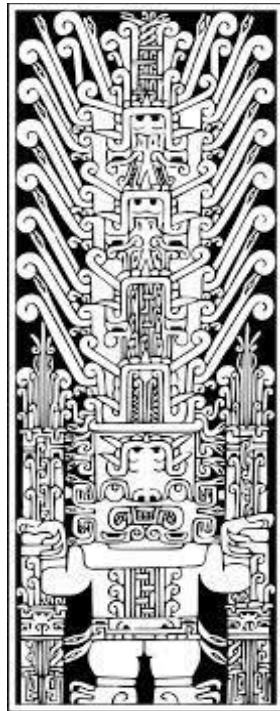


Universidad Nacional Federico Villarreal
Facultad de Ingeniería Industrial y de Sistemas
Escuela Profesional de Sistemas

Informe CEHv13 – Module 11: Session Hijacking



CURSO

Ciberseguridad

AUTOR

Aaron Mark Mina Rios

CODIGO

2021018505

Lima, Perú

2026

Introducción:

El secuestro de sesión (Session Hijacking) es una técnica de ataque que consiste en apropiarse de una sesión activa de un usuario legítimo, generalmente mediante el robo de la cookie de sesión, con el fin de acceder a una aplicación web sin necesidad de conocer las credenciales originales.

El presente informe documenta una práctica de laboratorio correspondiente al módulo 11 (Session Hijacking) del programa CEHv13, en la cual se utilizó la aplicación intencionalmente vulnerable OWASP Juice Shop, junto con las herramientas OWASP ZAP y CAIDO, para interceptar y reutilizar una cookie de sesión válida.

La actividad fue realizada íntegramente en un entorno controlado y aislado, con fines exclusivamente educativos, sin afectar sistemas ni usuarios reales.

Planteamiento del problema:

Muchas aplicaciones web dependen de cookies de sesión para mantener autenticado a un usuario tras el inicio de sesión. Si estas cookies no cuentan con mecanismos adecuados de protección (como los atributos HttpOnly, Secure o SameSite) o si el tráfico no viaja cifrado, un atacante que logre interceptarlas puede suplantar la sesión del usuario sin necesidad de conocer su contraseña.

Este escenario representa un riesgo crítico, ya que el atacante obtiene el mismo nivel de acceso que el usuario legítimo mientras la cookie robada permanezca válida.

Por ello, resulta necesario evidenciar de forma práctica cómo se ejecuta un ataque de secuestro de sesión y qué medidas de protección permiten mitigarlo.

Objetivos:

Objetivo General

Demostrar, mediante una práctica de laboratorio controlada, el proceso de secuestro de sesión (Session Hijacking) sobre una aplicación web vulnerable utilizando herramientas de interceptación de tráfico.

Objetivos Específicos

- Desplegar la aplicación vulnerable OWASP Juice Shop en un entorno controlado mediante Docker.
- Utilizar OWASP ZAP y CAIDO para interceptar y analizar el tráfico HTTP generado durante el inicio de sesión.
- Identificar y extraer la cookie de sesión asociada a un usuario autenticado.
- Reutilizar la cookie interceptada para acceder a la sesión activa sin conocer las credenciales originales.
- Analizar los riesgos asociados al robo de cookies de sesión y las medidas de mitigación correspondientes.

INFORME DE CEHV13 MODULE 11 SESSION HIJACKING

OWASP ZAP

```
kali@kali: ~  
Session Actions Edit View Help  
Fetched 75.9 MB in 20s (3,839 kB/s)  
536 packages can be upgraded. Run 'apt list --upgradable' to see them.  
  
(kali@kali)-[~]  
$ apt search zaproxy  
zaproxy/kali-rolling 2.17.0-0kali1 all  
Testing tool for finding vulnerabilities in web applications  
  
(kali@kali)-[~]  
$ sudo apt install zaproxy -y  
The following packages were automatically installed and are no longer required:  
libavc1394-0 libpostall libxmlsec1-1 python3-pluginbase  
libicu76 libssl2-classic libxmlsec1-openssl python3-pysnmp4  
libio-pty-perl libsimdt31 openjdk-21-jre  
libipc-run-perl libteamctl0 openjdk-21-jre-headless  
libpostal-data libunibreak postgresql-common-dev  
Use 'sudo apt autoremove' to remove them.  
  
Installing:  
zaproxy  
  
Summary:  
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 536  
Download size: 222 MB  
Space needed: 280 MB / 61.0 GB available  
  
Get:1 http://kali.download/kali kali-rolling/main amd64 zaproxy all 2.17.0-0kali1 [222 MB]  
Fetched 222 MB in 31s (7,206 kB/s)  
Selecting previously unselected package zaproxy.  
(Reading database... 433595 files and directories currently installed.)  
Preparing to unpack ../zaproxy_2.17.0-0kali1_all.deb...  
Unpacking zaproxy (2.17.0-0kali1)...  
Setting up zaproxy (2.17.0-0kali1)...  
Processing triggers for kali-menu (2026.2.5)...
```

CAIDO

```
(kali@kali)-[~/Downloads]  
$ sudo dpkg -i caido-desktop-v0.57.0-linux-x86_64.deb  
sudo: dpkg: command not found  
  
(kali@kali)-[~/Downloads]  
$ sudo dpkg -i caido-desktop-v0.57.0-linux-x86_64.deb  
Selecting previously unselected package caido.  
(Reading database... 433754 files and directories currently installed.)  
Preparing to unpack caido-desktop-v0.57.0-linux-x86_64.deb...  
Unpacking caido (0.57.0)...  
Setting up caido (0.57.0)...  
update-alternatives is /usr/bin/update-alternatives  
update-alternatives: using /opt/Caido/caido to provide /usr/bin/caido (caido) in auto mode  
Processing triggers for mailcap (3.76)...  
Processing triggers for desktop-file-utils (0.28-1)...  
Processing triggers for hicolor-icon-theme (0.18-2)...  
  
(kali@kali)-[~/Downloads]  
$ caido  
[45182:0610/114809.767611:ERROR:gpu/ipc/client/command_buffer_proxy_impl.cc:327] GPU state invalid  
after WaitForGetOffsetInRange.  
11:48:10.213 > On Linux, assuming AppImage updater  
11:48:10.223 > Detected deb package  
11:48:10.224 > Checking for update  
11:48:10.233 > Generated new staging user ID: 9aa57147-9cf5-5585-8603-6d0cd2635b38  
11:48:10.854 > Update for version 0.57.0 is not available (latest version: 0.57.0, downgrade is dis-  
allowed).
```

INSTALACION DEL OWASP-JUICISHOP

sudo apt update

sudo apt install docker.io -y

sudo systemctl start Docker

luego para la descarga y ejecución:

```
sudo docker pull bkimminich/juice-shop
```

```
sudo docker run -d -p 3000:3000 bkimminich/juice-shop
```

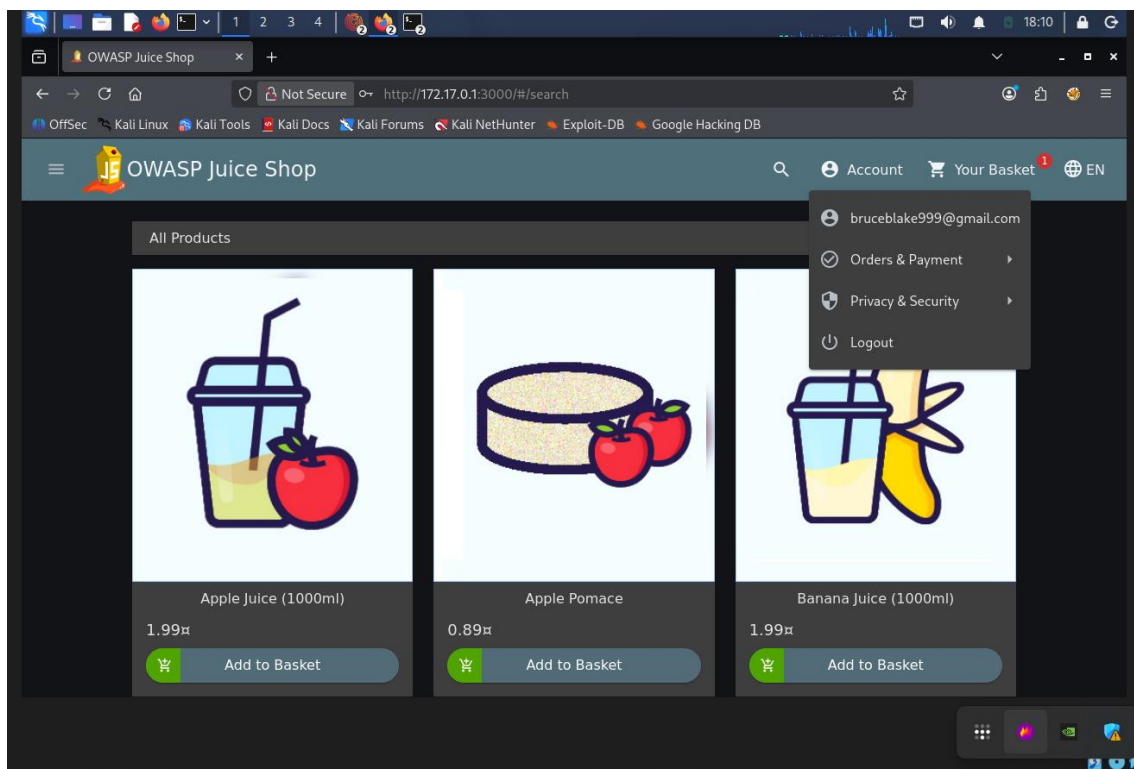
y en la página web debería aparecer:

<http://localhost:3000>

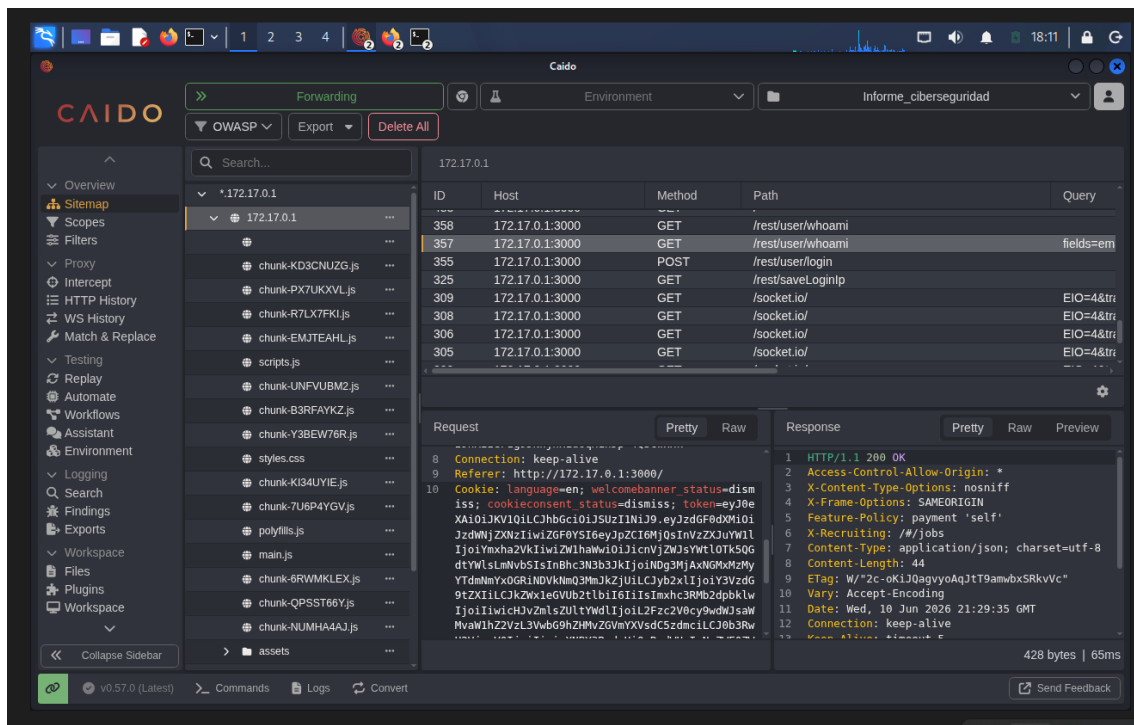
como el caído no detectaba en ese link se utilizo su ip que seria

<http://172.17.0.1:3000>

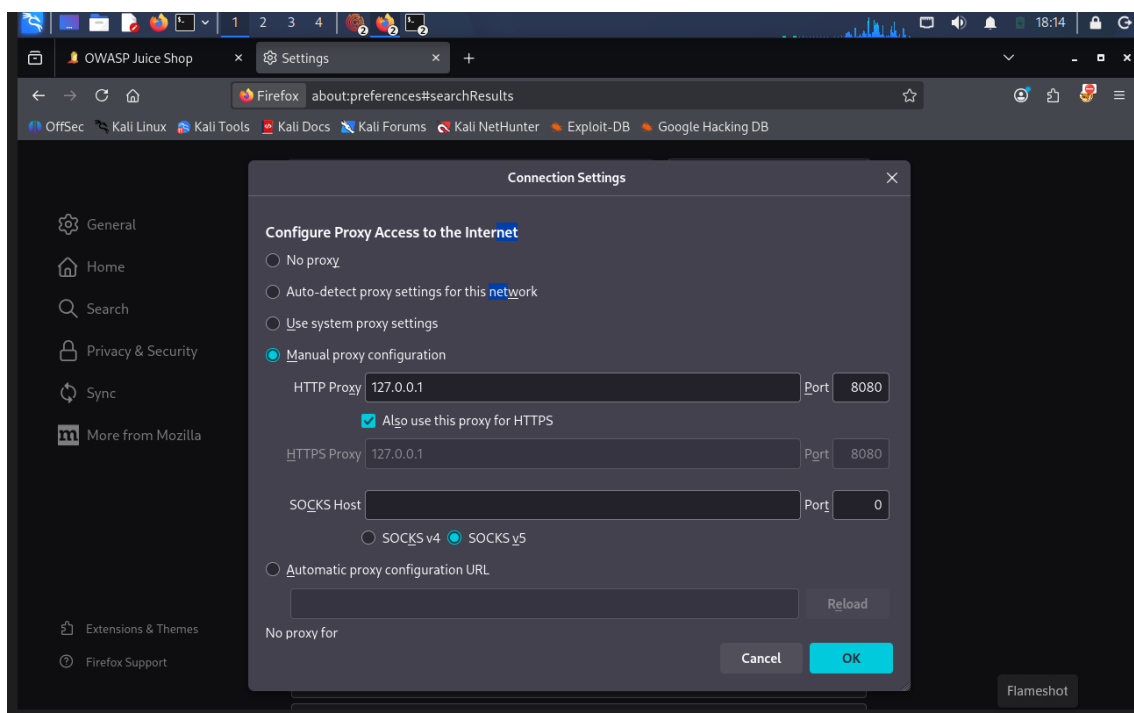
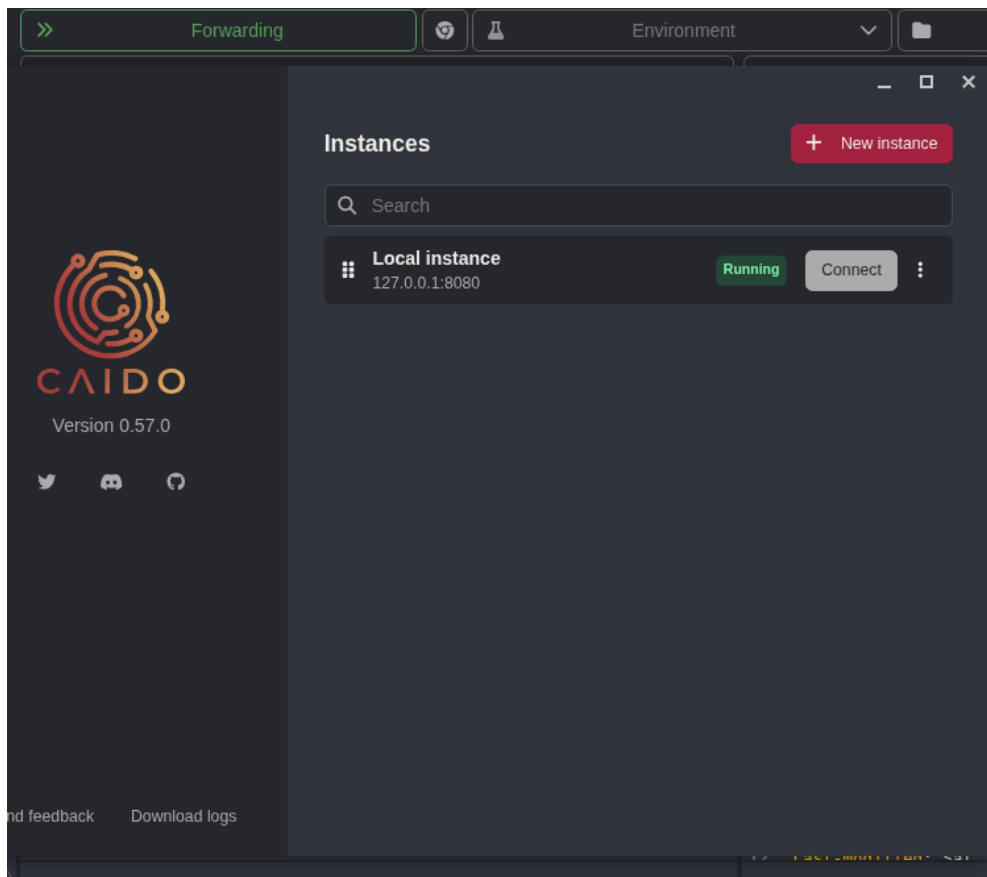
para el siguiente paso se realizo el inicio de login en la página web



el CAIDO detecta esta actividad y la registra junto con todos los movimientos en la página:

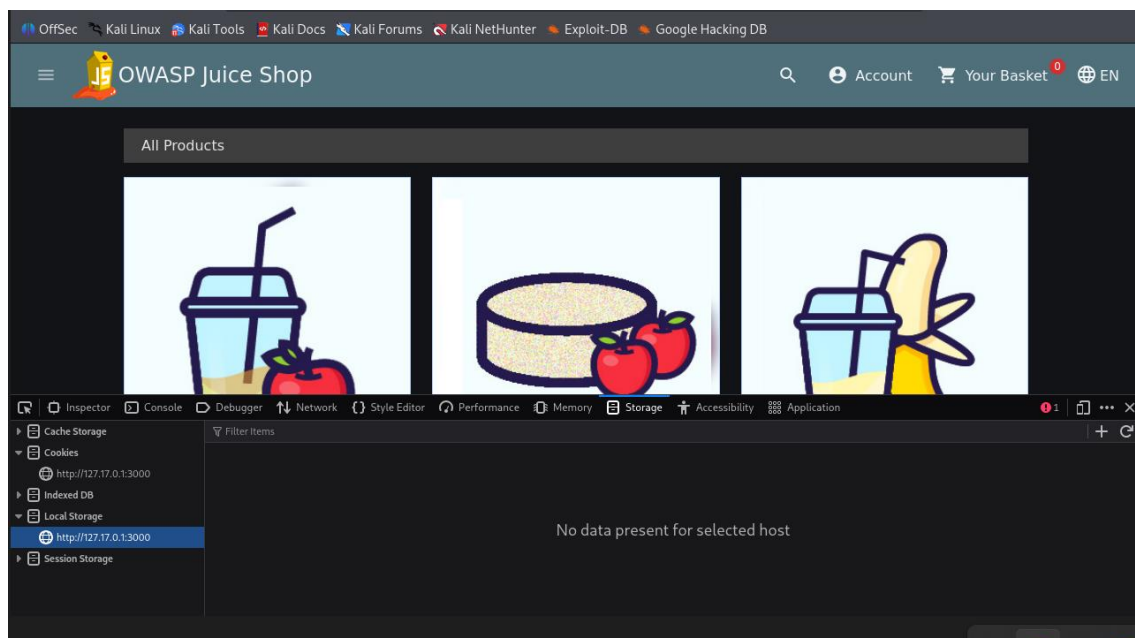
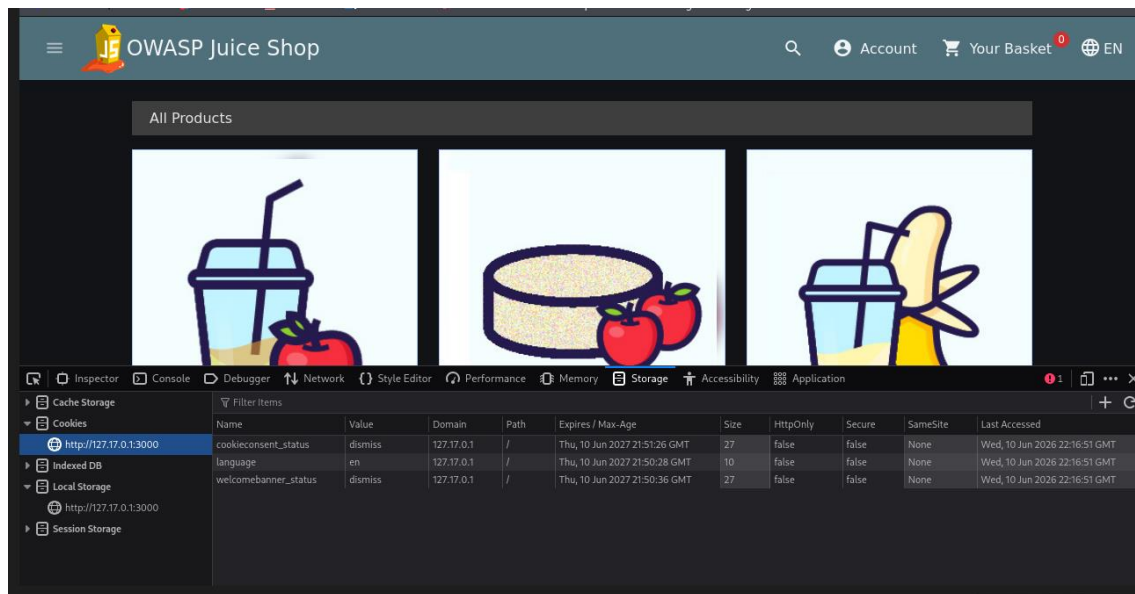


Adicionalmente:

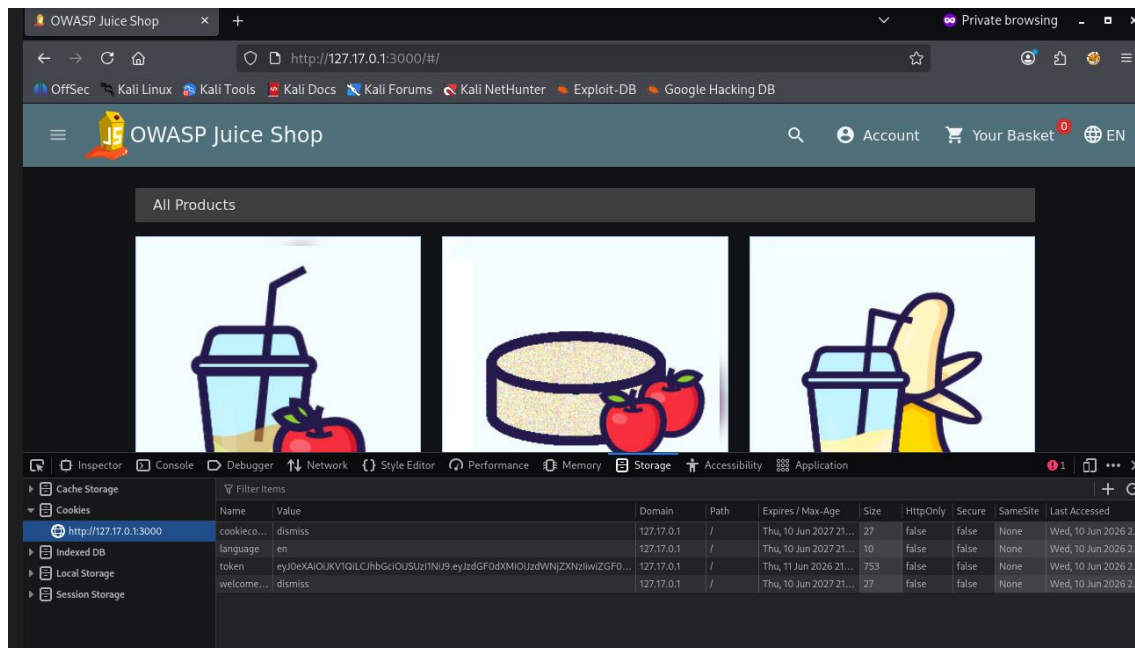


Para el robo de cookies se creo otra pestaña con el mismo link pero sin el login

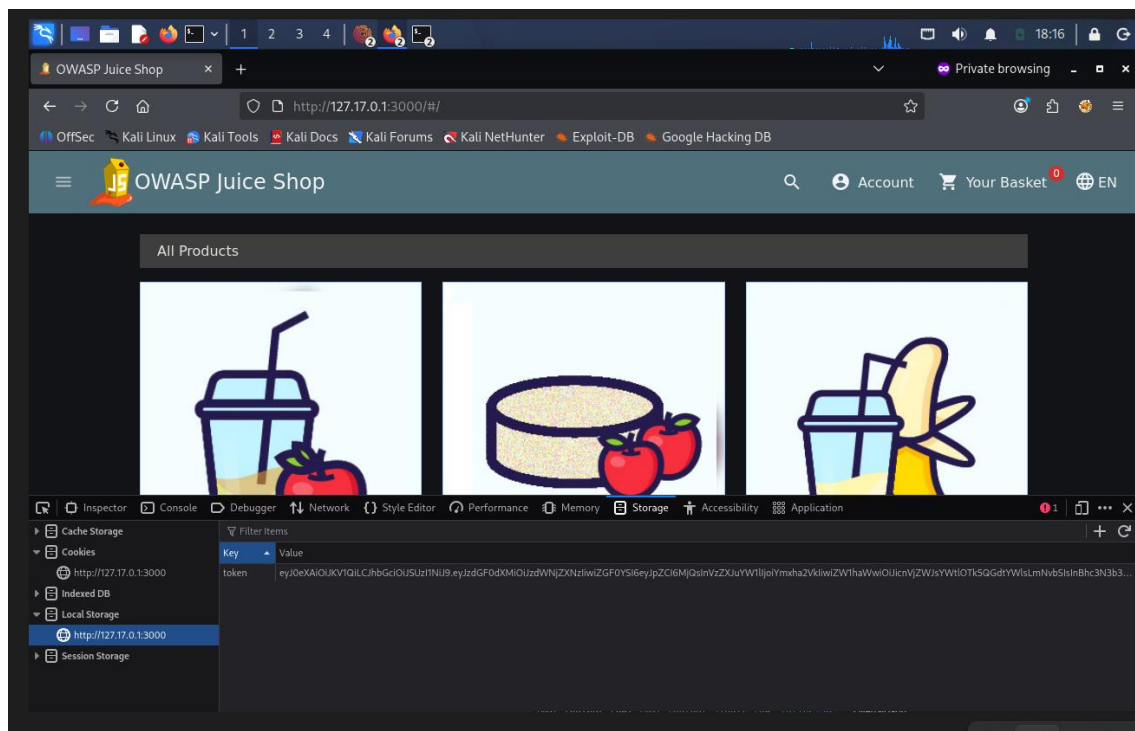
Al inicio la página estaba asi:



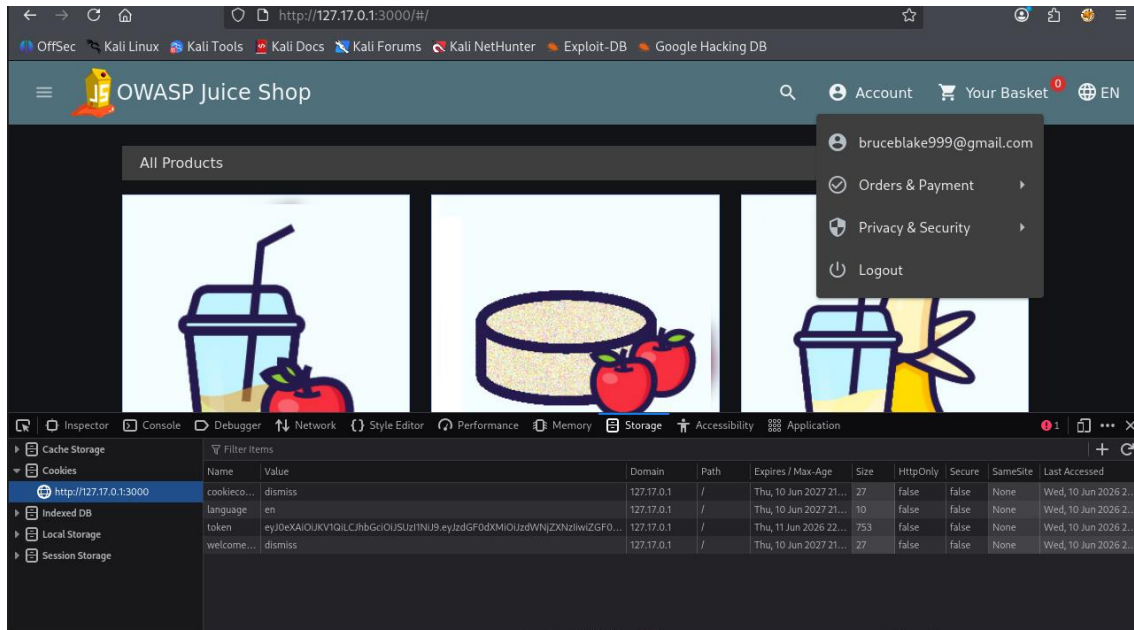
Luego de adicionar los datos proporcionados por CAIDO:



Aquí se observa cuando ya se agregaron el nombre y valor, del cookie para poder ingresar a la sesión



Se logro entrar a la sesión:



Ejecución del CAIDO:

